rr022 修改说明

论文：事件驱动智能体操作系统跨层能力治理方法

日期：2026 年 10 月 8 日

感谢编委和审稿人的意见。以下逐项说明修改内容，页码对应附后的清洁稿。审稿意见中 A1—A3 与 OPA-Tool 的连接符按正文记号统一排印。修改稿中，新增内容以下划线标注，删除内容以删除线标注。

R1.1 多环境验证

审稿意见：文章目前的实现主要基于单一 Agent OS 原型、单一模型、HTTP MCP 路径和 SQLite 后端，建议增加不同 Connector、工具传输方式、数据库后端以及其他 Agent OS 环境下的验证，以增强方法的通用性和外部有效性。

作者答复：增加了三类事件接入方式：HTTP Webhook、AMQP 消息和文件投递。它们分别代表请求推送、带确认和重投递的消息交付、非网络文件交换。工具调用比较 HTTP 和标准输入输出管道（stdio），持久化比较 SQLite 和 PostgreSQL。在相同输入和规则下，五组基本配置与一组组合配置共执行 42 项测试，授权结果均符合预期。合法及获批任务正常写入，违规调用被拒绝，重复交付没有产生重复任务或产物。

这些实验检验了更换接入、传输和存储方式后，授权检查及执行记录能否保持一致。实验接入 DiOS 的调度和治理组件，用固定工作流执行任务，并使用实际消息代理、数据库和工具服务。在同一宿主中逐项替换接入、传输和存储方式，可以分别观察各因素对治理结果的影响。另一 Agent OS 还需要接入相应任务入口、工具出口和状态生命周期；第 7.1 节说明迁移所需的接口，第 7.2.3 节将实验结论限定于 DiOS 及所测适配契约。

修改位置：第 5 节及表 3（第 11 页），第 6.8 节及表 18（第 19—20 页），第 7.1、7.2.3 节（第 20—21 页）。

R1.2 外部基线

审稿意见：目前外部基线主要采用 OPA-Tool，尚未直接复现 AgentSpec、OAP、ToolGuardian、Agent libOS 等代表性方法，建议补充更具可比性的实验。

作者答复：对照实验新增 AgentSpec 和 Agent libOS 的公开实现。选择这两项工作，是因为前者可比较动作和参数约束，后者可比较能力的签发、过期和撤销。AgentSpec 接入 DiOS 的事件准入流程，保留其规则解析和执行机制；Agent libOS 采用自身的能力管理和 MCP 调用路径。第 6.3 节说明了实现版本与适配内容，第 6.5.4 节报告了共同场景的比较结果。

此外，以 11 个未参与规则编写和调试的历史业务对象，比较 E2AG、使用完整上下文的 OPA 和 AgentSpec。三种配置各完成全部 11 个正常业务，并拒绝 33 条对象或版本不匹配的请求，结果一致。这些共同场景检验了判定机制与宿主授权关联的分工：现有规则和策略引擎实施相同约束，E2AG 负责事件、任务、能力和调用之间的关联及检查位置。OAP 和 ToolGuardian 的调用前授权机制在第 1.2 节比较；实验围绕动作与参数约束、能力生命周期两类问题，选择 AgentSpec 和 Agent libOS 的可运行公开实现。

修改位置：第 6.3 节（第 12—13 页），第 6.5.4—6.5.6 节及表 11—13（第 15—17 页）。

R1.3 性能评估

审稿意见：E2AG 引入双 PEP、能力签发、状态持久化和执行证据记录等机制，建议进一步量化任务准入延迟、工具调用额外开销、吞吐量以及不同并发规模下的性能变化，以评估其实用性。

作者答复：增加了测试服务器上的同路径配对测量。直通对照与完整 E2AG 采用相同代理、连接复用、工具服务和 PostgreSQL 后端，以 issue 受理和 PR 变更清单为两类业务，在并发数 1 和 8 下各做 5 轮配对，每配置预热 30 秒、测量 180 秒。第 6.7 节说明资源配额、运行顺序、计时检查及统计方法；表 16 报告端到端 p50、p95、完成速率、请求数及四组配对增量和轮次范围，表 17 区分任务准入、调用前处理、工具往返和调用后处理。

测量期 103389 项业务均完成且报告正确。并发 1 时，issue 和 PR 的配对中位延迟增量分别为 28.26 和 27.81 毫秒；并发 8 时分别为 112.50 和 114.72 毫秒。阶段记录显示，单并发 issue 的主要治理成本位于能力签发与调用证据持久化，而非纯规则判定。issue 并发 8 时相对延迟增加约 78%，完成速率由 57.24 降至 31.05 次/s，短时、高频业务需将这部分成本纳入延迟与容量预算。PR 并发 8 时两配置均出现 CPU 配额节流，其较小相对增量伴随更长的基准延迟。完成速率按所测资源配额和闭环并发负载解释。

修改位置：第 4.6 节（第 10 页），第 6.7.1—6.7.2 节及表 16—17（第 18—19 页），第 7.2.2 节（第 21 页）。

R1.4 细粒度权限

审稿意见：目前的能力主要约束工具集合，对合法工具内部的参数级违规、资源访问范围和敏感数据流缺乏直接限制。建议将参数谓词、资源作用域或数据流约束纳入能力模型，以增强细粒度安全控制能力。

作者答复：本文采用参数谓词和对象级资源约束。任务能力保存参数约束 K，调用时检查资源和版本标识、字段类型、整数范围及字符串长度。这样，即使工具名在允许集合内，访问其他资源、超过行数限制或传入错误类型的请求也会被拒绝。表 11 比较了仅检查工具集合、同时检查工具与参数的两种 E2AG 配置，以及 AgentSpec。在三类参数违规场景中，仅检查工具集合的配置仍执行请求；另外两种配置均拒绝请求，并保留合法调用。

资源约束通过匹配获准对象及版本标识实施，跨项目实验检查了相应读写权限。对于路径、符号链接或资源别名，需要由资源解析器确定实际对象。实验还将授权检查与报告内容检查分开：9 份权限合法但内容错误的报告可以写入，随后由业务核验程序识别。跨调用数据流约束未实现；第 7.1 节给出了将任务能力与数据来源标签结合的设计思路。

修改位置：第 2.3 节（第 5 页），第 4.3—4.4 节及算法 1—2（第 7—10 页），第 6.5.4—6.5.6 节及表 11—13（第 15—17 页），第 7.1 节（第 20—21 页）。

R2.1 相关工作和互补关系

审稿意见：相关工作对比以布尔特征标记为主，对现有能力系统、智能体防护方案为何无法直接复用解决本文问题分析深度不足；与 CaMeL、Agent libOS 等工作的互补关系论述简略。

作者答复：表 1 已改为比较各方法的可复用机制及接入事件驱动系统所需的工作。第 1.4 节结合代码推送任务说明：允许使用某个工具，还需知道该任务由哪个获准事件创建、审批针对哪个对象，以及调用能力是否仍然有效。OPA 或 AgentSpec 可以计算这些条件，但宿主需提供关联状态并执行决定。Agent libOS 已有进程、资源、工具和审批的能力中介；用于本文场景时，还需关联外部事件准入、系统任务和运行时能力，并保存相应授权证据。E2AG 研究的是这些跨层关系及其实施位置。

第 6 节分别以完整上下文 OPA 替换判定器、以 AgentSpec 实施共享准入后的调用规则，并用 Agent libOS 原生能力路径比较生命周期约束。这些是不同的比较配置，并非 E2AG 同时集成了三个系统。

与 CaMeL 的互补关系也在第 7.1 节展开：E2AG 检查任务授权和调用参数，CaMeL 通过数据标签约束信息流。二者结合时，可以在调用检查中同时使用任务能力与参数的数据来源标签。当前原型实现了参数检查，数据标签传播属于后续扩展。

修改位置：第 1.2—1.4 节及表 1（第 3—4 页），第 6.3 节（第 12—13 页），第 7.1 节（第 20—21 页）。

R2.2 形式化可读性与工程假设

审稿意见：形式化符号分散，缺少集中符号表；命题前提假设 A1—A3 的工程约束、现实风险讨论不足，对非形式化方向读者阅读不够友好。

作者答复：表 2 集中说明核心符号及其在算法中的用途。第 2 节先解释事件、任务和调用三个授权层，以及任务能力包含的权限和状态，再给出形式化定义；算法前集中解释了所用变量和辅助过程。调用算法在转发前保存调

用意图，取得并持久化响应后更新为“已收到响应”；未能取得或保存响应时保留“结果未知”。这一区分说明了通信或持久化失败后的处理。

对 A1—A3，第 4.6 节给出命题前提，第 5 节和表 3 说明对应的部署要求：入口须鉴别来源，工具调用须经过执行检查点，治理配置与状态存储须可信，准入至能力签发期间相关配置须保持稳定。授权有效性以调用检查时刻为准，撤销不追回已通过检查的在途请求；任务若能直连工具，则不满足完整中介前提。第 6.6.3 节检验 19 项对象关系反例及故障记录的处理，第 6.8 节检验不同接入、传输和存储方式下的状态更新与证据关联。

修改位置：第 2 节（第 4—5 页），第 4.4—4.6 节及表 2（第 7—10 页），第 5 节及表 3（第 11 页），第 6.6.3 节（第 17—18 页），第 6.8 节（第 19—20 页）。

R2.3 基线条件、业务样本与性能

审稿意见：OPA-Tool 基线实验条件说明埋于正文，容易被误读为 OPA 引擎本身能力缺陷；实验以人工构造冻结矩阵为主，真实业务样本数量少；缺少系统性能实测数据。

作者答复：第 6.3 节已将 OPA-Tool 的输入条件放在基线定义中说明：它接收工具名和允许集合，用来考察工具调用位置可见的信息。新增的 E2AG-with-OPA 向 OPA 提供事件、目标权限、能力状态和参数，由 Rego 计算授权决定，任务与审批仍由 DiOS 管理。这样可以区分输入信息的差异与策略引擎本身的能力。

业务样本方面，新增 GH Archive 固定 72 小时窗口内 ArcadeDB 和 Kibana 的 11 个历史对象，在规则固定后回放，包含 132 条主要比较运行。它们与编写规则时使用的两个开发对象分开统计；报告内容、工具日志和持久记录由另行编写的程序核验。数据来源及回放方式见第 6.5.6 节，比较结果见表 13。性能测量见第 6.7 节和对 R1.3 的答复。

修改位置：第 6.3 节（第 12—13 页），第 6.5.6 节及表 13（第 16—17 页），第 6.7 节（第 18—19 页）。

R2.4 绕过路径与组合机制

审稿意见：方法适用边界论述尚有扩充空间，对绕过 MCP 的调用路径风险、与参数级安全机制如何结合的实现思路介绍不足

作者答复：表 3 和第 7.1 节按任务入口与工具出口说明绕过风险。直接 A2A 入口和服务模式需要相应的准入检查；Skill、本地进程或任务自行建立的网络连接，需要通过访问隔离和系统出口控制限制其直接访问工具。这些路径若未受控，便不满足完整中介假设。

受控工具路径支持 HTTP MCP 和管理员允许清单中的 stdio 服务。两者均经能力代理；stdio 会话由代理管理，在初始化及工具调用前检查任务能力。撤销后的重新初始化与调用实验均返回拒绝，未启动新的工具进程。该结果检验的是另一种 MCP 传输路径上的授权实施。

参数约束 K 直接保存在任务能力中，由调用 PEP 检查实际参数，资源及版本标识、类型和范围的比较见 R1.4。第 7.1 节还说明了资源解析器与数据标签机制的组合位置：先确定实际资源对象，再结合任务能力和数据来源约束判断调用权限。原型实现了参数检查，资源解析和跨调用标签传播属于组合设计。

修改位置：第 5 节及表 3（第 11 页），第 6.8 节及表 18（第 19—20 页），第 7.1 节（第 20—21 页）。